LabTrail

A Patient-Controlled Longitudinal Lab Record
Solution Design Report — Assignment 2: Solution Architecture and Design

Author: Renee Raven **Email:** rraven2021@fau.edu
Course: CEN 5035 — Principles of Software Engineering **Instructor:** Dr. Fernando Koch **Date:** 10/10/26

1. Executive Summary

1.1 The problem and the stakeholder need

People who are managing an ongoing health condition rarely receive their laboratory work from a single source. A single patient may have blood drawn at an independent reference laboratory, at a hospital system's own laboratory, and at a specialist's office within the same year. Each organization releases results through its own patient portal, in its own document layout, with its own units of measure and its own reference intervals. The patient ends up holding a folder of unrelated documents rather than a history.

The consequence is that **a single test cannot be seen over time**. A value that has moved steadily in one direction across four draws at three organizations may look, to the patient, like four unrelated numbers. Trends and clues may be missed by clinicians and patients. Context that would explain the movement — a new medication, a dose change, a deliberate diet change, an illness during the collection week — exists only in the patient's memory and is recalled imperfectly, if at all, during a short appointment. The treating clinician sees whatever is inside their own record system plus whatever the patient managed to bring and remember.

Three stakeholder needs follow. The patient needs one ordered history per test and control over who sees it. The treating clinician needs outside results with their source and comparability caveats visible. The product steward and the privacy reviewer need the system to stay a patient-controlled record that never interprets a result.

1.2 Proposed solution direction

LabTrail is a patient-held longitudinal laboratory record. The patient imports their own lab reports. The system classifies each report, extracts the individual result rows as *candidates*, normalizes units, maps each analyte to a standard code, and presents the candidates for the patient to accept, correct, or reject. Only accepted values enter the record, and every accepted value stays linked to the report page it came from. The patient can attach dated context notes to the same timeline and can grant a named recipient — typically a treating clinician — scoped, expiring, revocable access to a defined slice of the record.

The central transformation is **many heterogeneous documents into one normalized, source-linked, patient-governed record**. This matches the Document Intelligence Agent AI Pipeline: classify the source material, extract the relevant content, assemble a candidate result, and verify it before it is delivered. Generative AI is used to classify reports and extract candidate values. It is not used to interpret them.

1.3 Architecture and design scope

The architecture follows the Document Intelligence pattern and adapts it to a record whose hosting operator cannot read its contents. It has fourteen components in four trust zones: the patient's device, a hosted ciphertext service, the recipient's browser, and external dependencies. Only the extraction components are non-deterministic. Normalization, review, timeline, redaction and access control are plain, testable code, which is how two retained-authority rules are enforced by structure rather than by convention: a clinician alone interprets a result, and the patient alone decides who may access the record. The two human decision points are the patient review queue and grant management.

Five design decisions shape the architecture. Each is recorded with its alternatives in Section 7.10. Extraction runs on the patient's device by default, with per-upload opt-in for cloud assistance. Key recovery is chosen by the patient at setup. Grant scope stays inside the encrypted share bundle. Grant keys are destroyed at both revocation and expiry. Recipient credentials are reusable for the life of the grant, with a second factor at every session.

1.4 Expected improvement

- A patient can see one ordered history for a single analyte across every laboratory that produced it, instead of reading isolated reports.
- A clinician receiving a share sees outside results with their source and their comparability caveats visible, instead of unsourced numbers read aloud or a stack of printouts.
- Context that explains a change is captured at the time it happens rather than recalled under time pressure at an appointment.
- Repeat testing ordered solely because prior results could not be located is reduced.
- Access is explicit, scoped, time-limited, revocable, and logged, rather than implied by handing over a folder, and the hosting operator cannot read the record.

2. Problem Scenario

2.1 Proof of Demand

Who cares? The people who experience this problem are clinicians who receive outside laboratory results with no provenance, nurses admitting patients whose results sit in a system unconnected to the hospital's, and patients and caregivers managing a chronic condition across several laboratories. I spoke with an attending oncologist about what it would take for him to trust a patient-provided record in a fast-paced setting, and I draw on my own work as a nurse and on helping to manage the care of an older family member.

Scenario 1 — The oncology admission, and validating clinician trust. In my practice as a nurse, I recently admitted an oncology patient who reported a critical value on her recent bloodwork from an independent reference laboratory. Because that laboratory is not connected to our hospital's record system and she lacked a hard copy, the medical team had to delay treatment to redraw her labs. To understand how we could solve this safely, I asked the attending oncologist what it would take for him to trust a patient-provided record in a fast-paced clinical environment. He confirmed he would use a patient-aggregated timeline only if he could instantly click a value to verify the source document's original header, units, and comparability flags, and said that source document would need to be transmissible and printable for the chart.

Scenario 2 — Complex chronic care management. I help manage the care of an older family member with several chronic conditions, resulting in dozens of lab reports from independent laboratories and hospital visits over the past two years. During a recent visit to her specialist, handing over sheaves of disconnected paper made it impossible to instantly spot longitudinal trends in her bloodwork. This absence of a combined history forces the doctor to spend the appointment manually cross-referencing papers rather than discussing proactive medication adjustments.

2.2 Comparison to Existing Tools

Existing tool	Core mechanism	Who holds the record	What makes LabTrail different
Apple Health Records	Connects a phone to participating providers over HL7 FHIR and assembles allergies, conditions, lab results, medications, procedures and vitals into one timeline.	The patient's device. Records are encrypted in the device's database, and end-to-end encrypted through iCloud when two-factor authentication is on.	**Participation is not a precondition.** Custody is strong, but records arrive only from connected organizations. LabTrail starts from documents the patient already holds.
Epic Share Everywhere	Lets a MyChart patient generate a share code that, with their date of birth, gives a clinician one-time temporary access to that chart.	The health system's chart. The patient controls access but does not hold a separate record.	**Scoped, per-analyte sharing.** Access covers one organization's chart and lasts until the recipient logs out. LabTrail grants a named recipient a defined analyte set and date range, with mandatory expiry, revocation, an access log, and source pages with every ungranted row masked.

Existing tool	Core mechanism	Who holds the record	What makes LabTrail different
PicnicHealth	Collects records from any United States care site under a single HIPAA authorization and labels them consistently so trends show across organizations. Offers an opt-in to contribute de-identified records to research.	PicnicHealth's servers. Identifiable records are visible to PicnicHealth.	**Valid comparison, not only consistent labels.** The reviewed documentation describes no step where the patient confirms an extracted value and no marking of changes in method or reference interval. LabTrail requires patient acceptance of every candidate, marks a series as not directly comparable where the source changes, keeps its hosted store unable to read the record (C-08), and forbids secondary use (NFR-01).

4. Functional Requirements and Validation Questions

Requirement ID	Functional Requirement	Validation Question	Expected Evidence or Test Result
FR-01	The system must accept a patient-initiated upload of a laboratory report as PDF or image and create a report record for it.	Can a patient import a report of each supported type, and is a distinct report record created for each?	Test set of synthetic reports imports without error; one report record per file, each retrievable by identifier.
FR-03	The system must extract, as candidates, each result row's analyte name, value, unit, reference interval, specimen type, and any abnormal flag printed on the report.	For a report containing a known set of result rows, are all rows extracted as candidates with the six attributes populated, and is each row's page and region recorded?	Per-row recall and per-field accuracy meet the thresholds in NFR-09; unextracted rows are reported as gaps; every extracted row carries a page number and a region.
FR-05	The system must resolve every candidate value to one of three outcomes... An unconvertible value must be retained in its original form and excluded from the canonical series.	Is an unconvertible value retained rather than dropped or coerced?	A mass-to-molar pair with no molecular weight on file is retained in its original unit, is absent from the canonical series, and states the reason.
FR-08	The system must route low-confidence, internally inconsistent, or conflicting extractions to patient review and must never accept them automatically.	Can any candidate reach the accepted record without an explicit patient acceptance event?	Audit of a full import run shows an acceptance event, with actor and timestamp, for every accepted value; deliberately degraded inputs all land in review.

Requirement ID	Functional Requirement	Validation Question	Expected Evidence or Test Result
FR-19	The system must serve a source page to a recipient only as a redacted rendering in which every result row outside that recipient's grant is masked.	Can a recipient granted one analyte read any other result from the page that analyte was printed on?	A grant for one analyte on a twelve-analyte panel yields a page on which the other eleven rows are masked and the view is labeled redacted.

5. Non-Functional Requirements

Requirement ID	Category	Measurable Requirement
NFR-01	Privacy	No record data is disclosed to any party other than the account holder except through an active patient grant. There is no secondary use.
NFR-03	Security	Record data and uploaded source files are encrypted at rest with AES-256, both on the patient's device and in the hosted store, and in transit with TLS 1.2 or higher.
NFR-08	AI conditions	Generative models are used only to classify reports and to propose candidate extractions. Model output never enters the accepted record without a recorded patient acceptance.
NFR-19	Redaction integrity	A source page served to a recipient is a flattened raster carrying no text layer. Masking drawn over a document leaves the underlying text selectable and extractable, so removal is required rather than concealment.

7. Solution Design

7.4 Interface Contracts

IF-04a — Create grant (CMP-09 and CMP-11 → CMP-13). On the device, CMP-09 passes scope to CMP-11 to build the bundle and run the text-extraction check (NFR-19). Network Request: `grant_id`, `bundle_id`, `bundle_ciphertext`, `expires_at`, `recipient_verification_data`. Response: `status: active`.

IF-05 — Recipient access (CMP-12 ↔ CMP-13). Authenticate: `credential`, `second_factor`, `recipient_identity` → short-lived session. Fetch: `session`, `bundle_id` → `bundle_ciphertext` and wrapped key. The browser decrypts locally.

7.5 Cryptographic Design & Key Management

To substantiate the constraint **C-08 (Custody Model)**—which mandates that the hosted service (Zone 2) operate as a content-blind storage provider—LabTrail implements client-side encryption, envelope encryption, and ephemeral key splitting.

1. Key Generation & Management (The Patient's Device — Zone 1)

- **Master Key Generation (*MK*):** During initial account creation, a client-side Cryptographically Secure Pseudo-Random Number Generator (CSPRNG) generates a local Master Key (*MK*).
- **Key Derivation Function (*KEK*):** The patient's passphrase, combined with a unique, randomly generated client-side salt, is processed through Argon2id to derive a Key Encryption Key (*KEK*).
- **Data Encryption Key (*DEK*):** A symmetric Data Encryption Key (*DEK*, AES-256-GCM) is generated on the client device. This *DEK* is used to encrypt all local source documents, candidate extractions, and verified records in Zone 1.
- **Key Wrapping:** The *DEK* is wrapped (encrypted) using the user's *KEK* (Wrapped *DEK* = AES-GCM-Wrap(*KEK*, *DEK*)) and stored locally or backed up via the patient's chosen recovery mechanism (FR-24). The plaintext *DEK* never leaves device memory.

2. Recipient Grant & Key Wrapping (Per-Share Cryptography)

When a patient creates a grant for a clinician (CMP-09), the system performs the following cryptographic steps to ensure Zone 2 remains completely content-blind (C-08, NFR-01):

- **Ephemeral Share Key (*SK*):** A fresh, random symmetric key (*SK*, AES-256) is generated solely for this specific share bundle.
- **Bundle Encryption:** The share bundle (containing only the allowed analytes, date range, and masked/flattened source pages) is encrypted using *SK* (Encrypted Bundle = AES-256-GCM(*SK*, Bundle Payload)).
- **Key Splitting / Server-Held Key Material:**
  - The Share Key *SK* is split or wrapped using a server-held authorization fragment: the **Recipient Token** (delivered out-of-band to the clinician via secure link) and the **Server Key Fragment** (*SK_Frag*).
  - The server-held storage (CMP-13) only holds *SK_Frag* alongside the ciphertext Encrypted Bundle.
  - **Cryptographic Proof:** Because the server *only* holds the fragment and never the complete decryption key *SK* (nor the patient's master key), **the hosting operator cannot decrypt or read the shared records at rest.**

3. Recipient Delivery & Session Decryption (Zone 3)

- **Authentication & Second Factor (FR-22, NFR-04):** The clinician clicks the secure link, enters their credentials, and completes a secondary out-of-band verification factor (e.g., OTP).
- **Key Reassembly:** Upon successful authentication, the Z2 gateway verifies the grant is active (checking expiry and revocation status), combines the server-held fragment with the recipient's validated request token, and transmits the complete decryption key *SK* exclusively to the clinician's browser session via TLS 1.3.
- **In-Memory Decryption:** The clinician's browser (CMP-12) fetches the Encrypted Bundle, uses *SK* to decrypt it entirely *in client-side memory*, renders the read-only redacted view, and wipes the key from memory upon session termination or timeout (15-minute idle rule, NFR-04).

4. Revocation and Expiry Enforcement (Destruction of Key Material)

- **Zero-Knowledge Revocation (FR-15, NFR-20, DR-04):** When a patient revokes a grant or when its expiry timestamp passes, the hosted service (CMP-13) immediately purges and cryptographically shreds the corresponding *SK_Frag* from its database within the 5-second SLA (NFR-12).
- **The Result:** Even if a malicious actor or the hosting operator attempts to access the Encrypted Bundle stored on Z2 after revocation or expiry, decryption is mathematically impossible because the key material has been permanently destroyed.

7.6 State Models

Review lifecycle of a result value.

- **Held** covers four blocking causes: a missing registration field, an unconfirmed identity, an unmapped analyte, and a duplicate awaiting a decision.
- Only the patient's actions move a value out of Candidate. There is no automatic transition and no timer.
- A withdrawn value is retained as rejected, absent from every view, and recoverable from the audit record.

Grant lifecycle.

- **Draft** exists only on the patient's device. A bundle that fails the text-layer check stays in Draft.
- **Active** is where recipient access happens. Each access writes an audit event before the bundle is released.
- **Ended** is terminal. Revocation destroys the server-held key material and ends active sessions within 5 seconds.

7.7 Processing Rules (Normalization Engine, CMP-03)

CMP-03 is a pure function of the candidate and the reference-data release in force. Rules run in this order: map the analyte, resolve the unit, detect duplicates, flag for scrutiny.

7.8 Control Logic and Exception Handling

Principles.

1. **Fail closed on access.** If a control cannot be enforced, recipient access is refused (NFR-15).
2. **Fail visible on data.** A missing, unreadable or unconvertible item appears as a gap or a labeled exception. It is never dropped or guessed.
3. **No automatic acceptance.** No failure path ends in an accepted value (FR-08).

Degraded operation (NFR-15). If extraction is unavailable, the accepted record, timelines and active grants stay fully available. If the grant store is unavailable, recipient access is refused while the patient's own record, which lives on the device, is unaffected.

7.9 How Information Moves Through the Solution

1. **Import.** The patient uploads a report. CMP-01 stores the file as received, registers it, and extracts the asserted identity.
2. **Extraction.** CMP-01 calls CMP-02 (IF-01) with the chosen mode. The adapter returns a CandidateExtractionResult.
3. **Normalization.** CMP-03 maps the analyte, resolves the unit, detects duplicates, and flags rows for scrutiny.
4. **Review.** The patient sees each candidate with its source region. Through IF-03 the patient accepts, corrects or rejects it.
5. **Correction and withdrawal.** A correction replaces the value and flags it corrected_by_patient; the original stays recoverable.
6. **Display.** CMP-08 reads accepted values only and draws the timeline in collection-date order.
7. **Grant.** The patient chooses a recipient, an analyte set, a date range and an expiry. CMP-11 builds an immutable bundle. Z2 stores ciphertext.
8. **Recipient access.** The clinician opens the link, presents the credential and the second factor, and Z2 writes an audit event and releases the bundle.
9. **End.** The grant ends by revocation or by expiry. The server-held key material is destroyed.

7.10 Design Decision Records

- **DR-01 — Where extraction runs:** On-device by default, cloud assist by explicit opt-in.
- **DR-02 — Key recovery:** Baseline recovery phrase required. Platform-synced key store is optional. No operator escrow allowed.
- **DR-03 — Grant scope & access log:** Grant scope (analytes, dates) exists only on device and inside encrypted bundle. Hosted service stores identifiers and expiry only.
- **DR-04 — Key destruction:** Server-held key material is destroyed at revocation AND expiry.
- **DR-05 — Recipient credential:** Bound to one grant/recipient, reusable. Second factor required every session. 5-failure lockout.

8. Implementation Guidelines

8.1 Prototype Boundary

Built: one web client (Z1), a small hosted service (Z2) with the gateway and audit log, a recipient viewer (Z3), and the Extraction Port with at least one adapter. All data is synthetic (NFR-18).

Specified but not built: the trusted-contact key split, caregiver or proxy access, automated portal import, and multi-device sync.

8.2 Implementation Order

The order follows the component dependencies: SC-01 and SC-02 first, then SC-04.

- **Phase 1: Deterministic core.** CMP-03 normalization, CMP-05 candidate store, CMP-06 review workbench, CMP-07 accepted record.
- **Phase 2: Import and extraction.** CMP-01 import and registration; CMP-02 Extraction Port with the first adapter.
- **Phase 3: Sharing.** CMP-11 redaction; CMP-13 gateway and store; CMP-09 grant manager; CMP-12 recipient viewer.

Invariants the design enforces. Each becomes a test (Section 8.5):

1. A value changes status only through a ReviewEvent, and no candidate or rejected value reaches CMP-08, CMP-11 or CMP-12.
2. A value whose report and page cannot be resolved is not displayed (NFR-05).
3. `canonical_value` exists only for the first two conversion outcomes, and an unconvertible value never appears in the canonical series (FR-05, FR-12).
4. A `region_unavailable` value never causes a source page to be served to a recipient (FR-20).
5. Accepted values are never recomputed silently when reference data changes. The patient is shown the affected values for review (NFR-17).
6. Z2 holds ciphertext, grant metadata and audit events only.
7. A share bundle never changes once built. Newer data, corrections or withdrawals reach a recipient only through a new grant.
8. Ended is terminal, and `ended_reason` is set once.

Appendix A: Complete Change Log

Part A. Adopted Changes

ID	Change	Rationale
CL-01	FR-05 third outcome extended to non-numeric results.	Normalization rules needed deterministic outcome.
CL-02	Terms fixed: unconvertible value, canonical series, not-plotted section.	Ensures tests match requirements perfectly.
CL-03	Extraction runs on device by default; cloud opt-in behind Port (FR-23).	Opt-in keeps decision with patient (C-08).
CL-04	Patient chooses recovery method at setup (FR-24).	Operator cannot recover content under C-08.
CL-05	Grant scope stays inside encrypted share bundle.	Which tests are shared is health information.
CL-06	Grant key material destroyed at expiry (DR-04, NFR-20).	Removes dependency on path checking dates.

ID	Change	Rationale
CL-07	Recipient credential reusable; 2FA every session (DR-05).	Works on hospital workstations; strong auth.
CL-08	Patient can withdraw accepted value to rejected.	Preserves audit trail vs. hard delete.
CL-09	Bulk acceptance only for unflagged values after opening page.	Reduces review fatigue without breaking FR-08.
CL-10	Unreachable revocation is pending, queued, retried.	Patient must not be told access ended when it hasn't.
CL-11	"Unit basis" means measurement basis, not scale.	Prevents UI noise from exact scale conversions.
CL-12	OQ-09 resolved as supported by display only.	Adding links moves toward excluded integration.
CL-13	NFR-15 99.5% availability restated as design target.	Cannot be formally shown by a prototype alone.
CL-14	NFR-01 names cloud-assist flow and metadata observed.	Disclosure inventory must list actual flows.
CL-15	Share bundles are immutable snapshots.	Consequence of encrypting on device at grant time.
CL-16	FR-17 recipient document produced in browser.	Keeps hosted service unable to read content.
CL-17	Model's proposed analyte code shown as suggestion only.	Keeps normalization deterministic.
CL-18	Layered pipeline selected over microservices.	Provenance tracking simpler in sequential flow.
CL-19	Candidate-extraction payload requires bounding region.	Supports FR-03 and one-click provenance.

Part B. Not Adopted / Superseded

ID	Item	Rationale
CL-20	Grant-scope payload on server not adopted.	Conflicts with CL-05 and CL-06.
CL-21	Text-based architecture flow superseded.	Diagram shows trust zones better.
CL-22	Three-phase implementation merged to seven-increment.	Better separates key management and risk.
CL-23	Condensed tables not adopted.	Baseline dependencies are still required.
CL-24	Earlier draft heading superseded.	Updated course and date.
CL-25	Rewritten competitor comparison not adopted.	Stays within bounds of reviewed vendor documentation.